

Non-Human Identities and SOC 2 Compliance: A Formal Analysis of Structural Governance Gaps in Multi-Platform Enterprise Environments

Manu Prakash Bhat, Umang Mishra, Merin Meleet, and Chethana Murthy

Abstract—The SOC 2 Trust Service Criteria were designed around human user accounts—password policies, multi-factor mandates, periodic access reviews—and contain no explicit life-cycle controls for *non-human identities* (NHIs): service principals, personal access tokens, deploy keys, workflow secrets, managed identities, Key Vault secrets, and TLS certificates. Machine credentials outnumber human identities by ratios exceeding 45:1 in enterprise deployments, yet a SOC 2 Type II audit can pass while hundreds of over-privileged or unrotated NHIs remain unexamined. This paper presents NHI-GUARD, an automated governance framework addressing this structural gap through: (i) unified multi-source discovery across GitHub, Microsoft Azure, and PKI surfaces; (ii) a three-layer risk engine combining deterministic 100-point scoring, per-scan Isolation Forest anomaly detection on nine-dimensional feature vectors (surfacing 8.3% of findings as statistical anomalies invisible to rule-based systems), and GPT-4o natural-language rationale generation; (iii) dual policy enforcement pairing Python rules with OPA/Rego policy-as-code mapped against SOC 2 CC6 and CC7 controls; and (iv) a continuous compliance posture score replacing binary audit outcomes with per-scan trending. Evaluation across 90 production scans demonstrates that NHI-GUARD detects credential risk classes structurally invisible to SOC 2 audits. A predictive regression model forecasts 30-day risk trajectory with $R^2 > 0.89$ (MAE = 3.8 on a 0–100 scale) in stable environments, enabling proactive remediation before credentials reach exploitable states.

Index Terms—Non-human identity, SOC 2, machine credential governance, Isolation Forest, policy-as-code, compliance posture, DevSecOps, cloud security, risk scoring.

I. INTRODUCTION

WALK through the IAM console of any mid-sized cloud deployment and two populations become visible—though security tooling tends to acknowledge only one. The human-account population is well-trodden ground: decades of practitioner experience have produced a dense ecosystem of controls for password hygiene, second-factor enrollment, quarterly access recertification, and trigger-based deprovisioning. The second population receives no comparable attention. Service principals, API tokens, deploy keys, and workflow secrets operate continuously in the background, authenticating thousands of inter-service calls per hour, accumulating permissions over time, and aging past any sensible rotation deadline—largely unobserved.

M. P. Bhat and M. Meleet are with the Department of Information Science and Engineering, RV College of Engineering, Bengaluru 560059, Karnataka, India (e-mail: manuprakashb.is22@rvce.edu.in; merinmeleet@rvce.edu.in).

U. Mishra and C. Murthy are with the Department of Computer Science and Engineering, RV College of Engineering, Bengaluru 560059, Karnataka, India (e-mail: umangmishra.cs22@rvce.edu.in; chethanamurthy@rvce.edu.in).

These non-human identities—the machine credentials stitching together modern microservice architectures—have grown far beyond what most security programmes were designed to govern. Gartner’s 2024 IAM predictions estimated that 75% of cloud security failures through 2025 would trace back to inadequate management of machine identities [1, p. 4]. The 2024 Verizon Data Breach Investigations Report found credential compromise behind 31% of all breaches, with service account abuse representing a growing share [2, p. 8]. The OWASP Non-Human Identities Top 10—released in its inaugural 2025 edition—catalogues ten distinct attack categories from improper offboarding through long-lived secrets to human misuse of machine credentials [3].

The dominant compliance framework for cloud-native organisations—SOC 2, administered under the AICPA Trust Service Criteria—does not engage with any of this. Its controls name no rotation schedule for personal access tokens, set no age ceiling for deploy keys, and define no expiry requirement for Key Vault secrets. An organisation can hold an unqualified Type II opinion while simultaneously running infrastructure secured by three-year-old write-access credentials that no auditor has examined.

A. The Structural Blindspot

Reading the four criteria most applicable to credential governance reveals a consistent pattern. CC6.1 concerns restricting unauthorized logical access to systems. CC6.6 addresses prompt removal of access when it is no longer justified. CC7.2 focuses on monitoring infrastructure components for behaviourally anomalous activity. CC7.3 concerns classifying and evaluating detected security events. Each criterion describes a governance action without specifying the identity type to which it applies. In practice, auditor evidence requests for these controls consistently target human user accounts—MFA reports, user access review screenshots, offboarding tickets—because the criteria themselves supply no alternative framing. Evidence collection remains overwhelmingly point-in-time: configuration exports, interview transcripts, quarterly screenshots.

B. Contributions

Against this backdrop, the work reported here pursues five goals:

- 1) A **formal gap analysis** mapping SOC 2 TSC controls to NHI risk categories, demonstrating precisely which credential attack vectors fall outside audit scope.

- 2) A **unified NHI taxonomy** spanning eleven identity types across three cloud surfaces (GitHub, Azure, PKI) under a single risk model.
- 3) A **three-layer risk engine**: deterministic scoring, Isolation Forest anomaly detection on nine-dimensional feature vectors, and LLM-generated auditor-readable rationale.
- 4) **Dual policy-as-code enforcement** via OPA/Rego with direct 1:1 mapping to SOC 2 CC6/CC7 controls, producing machine-verifiable compliance evidence.
- 5) A **continuous compliance posture score** replacing binary audit opinions with a measurable, per-scan metric that trends over time.

II. BACKGROUND AND RELATED WORK

A. SOC 2 Trust Service Criteria

SOC 2 is a voluntary assurance standard published by the AICPA [9]. Five Trust Service Categories—Security, Availability, Processing Integrity, Confidentiality, and Privacy—form the basis of attestation reports. The Security category’s Common Criteria (CC6.1, CC6.6, CC7.2, CC7.3) carry the controls most pertinent to identity governance; Section I-A details how each was drafted with human accounts as the implicit subject. They establish no rotation frequencies, type-specific thresholds, or evidence requirements for machine credentials.

B. The Non-Human Identity Problem

The term “non-human identity” encompasses any programmatic credential that software, services, or automation use for authentication without real-time human involvement [4]. Unlike human accounts—which have dedicated lifecycle workflows for onboarding, recertification, and termination—NHIs are typically provisioned for narrow operational purposes (a CI/CD pipeline credential, a monitoring agent token, a microservice authentication secret) and then forgotten. They accumulate without inventory. They age without rotation. And they retain over-privileged scopes inherited from initial provisioning decisions made months or years earlier.

The inaugural OWASP Non-Human Identities Top 10, released in 2025, provides a structured taxonomy of machine-credential failure modes [3]. Four categories bear directly on this work. *Improper offboarding* (NHI1) concerns credentials persisting after the service or personnel they were provisioned for have been retired. *Secret leakage* (NHI2) captures incidents where credentials are inadvertently embedded in source code or execution logs. *Overprivilege* (NHI5) describes the common condition where a credential’s granted scope substantially exceeds its operational requirement. *Long-lived secrets* (NHI7) characterises credentials lacking defined expiry dates or rotation schedules. Each of these failure modes can be present in a production environment that holds a current, unqualified SOC 2 opinion.

C. Related Work

Detection-focused tools. GitGuardian [5] detects hardcoded secrets in source repositories—a valuable but narrow capability addressing NHI2 (Secret Leakage) alone, without assessing

credential age, privilege scope, or compliance posture. Its 2024 report notes that 70% of secrets first exposed in 2022 remained valid two years later [5, p. 12], underscoring the staleness dimension our scoring model captures. Microsoft Entra Workload Identities [6] provides governance for Azure service principals and managed identities but ignores GitHub PATs, deploy keys, and TLS certificates entirely. CertSpotter [7] monitors TLS certificate issuance via Certificate Transparency logs but lacks integration with enterprise credential rotation workflows. None of these tools produces a compliance posture metric or maps findings to audit controls.

Workload identity standards. The SPIFFE (Secure Production Identity Framework for Everyone) specification and its reference implementation SPIRE [13] provide cryptographic workload identity issuance for service meshes. SPIFFE eliminates long-lived secrets by issuing short-lived X.509 SVIDs, addressing NHI7 at the infrastructure level. However, it covers only runtime authentication—it does not inventory existing static credentials, assess their risk, or produce compliance evidence. Environments adopting SPIFFE still retain legacy PATs, deploy keys, and Key Vault secrets that require separate governance.

Standards and frameworks. CIS Controls v8 (Control 5) covers service account management but provides no automation framework [12]. ISO 27001:2022 Annex A.9 addresses access control with marginally more specificity than SOC 2 regarding service accounts, yet defines no machine-specific thresholds or continuous monitoring requirements [11]. NIST SP 800-63B describes authenticator lifecycle management scoped explicitly to human authentication contexts [10]. NIST SP 800-207 (Zero Trust Architecture) advocates eliminating long-lived credentials in favour of short-lived, automatically expiring alternatives [14], but offers no implementation-level guidance for credential inventory or risk scoring across heterogeneous cloud platforms.

Breach evidence and commercial tools. Real-world exploitation of NHI weaknesses is well-documented: the Midnight Blizzard campaign (2024) leveraged an over-privileged OAuth app in a legacy tenant [15], while the Heroku/Travis CI incident (2022) exploited improperly offboarded OAuth tokens [16]. Commercial platforms—CyberArk [17], Venafi, Astrix, and Silverfort [18]—address subsets of the NHI problem but none provides unified cross-platform risk scoring with SOC 2 control mapping and continuous compliance measurement.

A survey of published tools and standards reveals no framework that simultaneously addresses version control credentials, cloud identity provider secrets, and PKI certificates within a unified governance model—let alone one with explicit SOC 2 control mappings and continuously updated compliance measurement. The gap reflects a broader pattern: prior work has framed NHI governance primarily as a detection problem rather than a compliance measurement problem.

III. THE SOC 2 GAP: FORMAL ANALYSIS

We formalise the coverage gap to demonstrate that it is structural—not a matter of auditor oversight, but a property of the criteria themselves.

TABLE I
SOC 2 CC6/CC7 COVERAGE OF NHI RISK VECTORS

NHI Risk Vector	CC6.1	CC6.6	CC7.2	CC7.3
PAT write-scope rotation	~	×	×	×
Deploy key age / write access	~	×	×	×
Actions secret rotation	×	×	×	×
Service principal secret expiry	~	~	×	×
Key Vault secret rotation	×	×	×	×
TLS certificate expiry	×	×	~	×
Dormant identity detection	×	~	×	×
Privilege scope creep	~	×	×	×
Third-party secret provenance	×	×	×	×
Anomalous credential patterns	×	×	~	~
Cross-platform NHI inventory	×	×	×	×

~ = partial/interpretive; × = not addressed

Definition 1 (NHI Governance Coverage). Let $\mathcal{C} = \{c_1, \dots, c_k\}$ denote SOC 2 controls relevant to access management. Let $\mathcal{N} = \{n_1, \dots, n_m\}$ be the NHI types in a given environment. The governance coverage of control c_i over NHI type n_j is:

$$\text{cov}(c_i, n_j) = \begin{cases} 1 & \text{if } c_i \text{ explicitly addresses } n_j \\ 0 & \text{otherwise} \end{cases}$$

Aggregate coverage: $\Gamma = \sum_{i,j} \text{cov}(c_i, n_j) / (k \cdot m)$.

Proposition 1 (SOC 2 NHI Coverage is Effectively Zero). For the eleven NHI types catalogued in Section IV and the four CC6/CC7 controls, $\Gamma = 0$ under standard audit interpretation, because no TSC criterion names any NHI type, rotation threshold, or machine-identity lifecycle requirement.

Table I makes this concrete. Each cell records whether a SOC 2 control structurally addresses the corresponding NHI risk vector.

The bottom row is perhaps most telling: cross-platform NHI inventory—simply *knowing* what machine credentials exist—falls entirely outside SOC 2 scope. A compliance programme cannot remediate what it cannot enumerate.

IV. THE NHI-GUARD FRAMEWORK

A. Architecture

NHI-GUARD operates as a six-agent pipeline orchestrated by a LangChain tool-calling agent backed by GPT-4o. Figure 1 shows the processing flow. Each agent exposes a typed LangChain tool; the orchestrator invokes them in sequence, passing structured JSON between stages. The architecture is deliberately linear—discovery feeds scoring, scoring feeds policy, policy feeds ML analysis, ML feeds reporting, reporting triggers alerting—making the audit trail unambiguous. Every finding carries full provenance from raw API response through to final severity classification.

B. Discovery Layer: Unified NHI Taxonomy

The framework discovers eleven NHI types across three cloud surfaces.

GitHub surface. A dedicated agent enumerates deploy keys (creation date, write-access flag), Actions secrets (last-updated timestamps), PAT metadata (OAuth scopes,

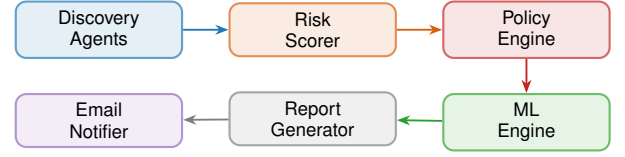


Fig. 1. NHI-GUARD pipeline. Discovery agents feed three cloud surfaces into risk scoring, policy evaluation, ML-driven anomaly detection, report generation, and severity-routed alerting.

expiration), and workflow secret references parsed from `.github/workflows/*.yaml`.

Azure surface. Three sub-agents query Microsoft Graph for service principal secrets/certificates, the Azure Key Vault SDK for vault-stored secrets and keys, and Azure Monitor sign-in logs for dormancy detection (configurable inactivity window; default 7 days).

PKI surface. The certificate agent probes TLS endpoints, extracts leaf certificate expiry, and flags certificates within 30/60 days of expiration at CRITICAL/MEDIUM severity.

All findings normalise into a unified schema: `nhi_type`, `score`, `severity`, `days_left`, `is_dormant`, `read_only`, `scopes`, `secret_origin`, `risk_reason`.

V. THREE-LAYER RISK ENGINE

A. Layer 1: Deterministic Scoring (0–100)

Each finding receives a deterministic numeric score from four bounded additive components:

$$\text{score}(f) = S_{\text{type}}(f) + S_{\text{age}}(f) + S_{\text{priv}}(f) + S_{\text{ctx}}(f) \quad (1)$$

Type component ($S_{\text{type}} \in [0, 30]$). Base weight reflecting inherent credential-category risk. Write-access PATs and write deploy keys receive the maximum 30 points; client secrets score 22; service principal objects 20; Key Vault secrets and keys 15–20; read-only deploy keys 10; TLS certificates 8. Calibration was performed against the OWASP NHI Top 10 risk rankings and blast-radius analysis [3].

Age component ($S_{\text{age}} \in [0, 40]$). Credential staleness carries the heaviest single weight:

$$S_{\text{age}}(f) = \min\left(40, \left\lfloor 40 \cdot \frac{t(f)}{\tau(f)} \right\rfloor\right) \quad (2)$$

where $t(f)$ is age in days and $\tau(f)$ is the type-specific rotation threshold: 30 days for write PATs, 60 days for write deploy keys, 90 days for Actions secrets and Key Vault secrets. This design reflects GitGuardian’s observation that 70% of secrets first exposed in 2022 remained valid two years later [5]—staleness being the strongest single predictor of exploitability in practice.

Privilege component ($S_{\text{priv}} \in [0, 20]$). Points accrue per high-privilege indicator: `admin:org` scope contributes 10 points, `repo` and `workflow` scopes 7 each, write deploy key flag 10, and dormancy adds 15 (total capped at 20). The dormancy penalty reflects OWASP NHI1: a dormant credential retaining broad permissions is a pre-positioned lateral-movement path.

Context component ($S_{\text{ctx}} \in [0, 10]$). Bonus points for certificate findings in CRITICAL/WARNING status, third-party provenance, or absent ownership metadata.

Severity labels: $\geq 70 \Rightarrow \text{CRITICAL}$; $\geq 50 \Rightarrow \text{HIGH}$; $\geq 30 \Rightarrow \text{MEDIUM}$; $< 30 \Rightarrow \text{LOW}$.

B. Layer 2: Isolation Forest Anomaly Detection

Deterministic scoring catches threshold violations but cannot identify credentials that are *statistically unusual* within their population yet technically compliant. We address this with an Isolation Forest [8] trained fresh on each scan’s findings. The model operates on a nine-dimensional feature vector:

$$\mathbf{x}_i = [c_{\text{type}}, s_i, c_{\text{sev}}, \min(t_i, 365), w_i, |\mathcal{S}_i|, d_i, \text{tp}_i, \text{dom}_i] \quad (3)$$

where: c_{type} is an ordinal type code (0–10); s_i is the deterministic score; c_{sev} is severity ordinal (0–3); t_i is age in days, capped at 365; $w_i \in \{0, 1\}$ is write-access; $|\mathcal{S}_i|$ counts OAuth scopes; d_i is days remaining for certificates (–1 otherwise); $\text{tp}_i \in \{0, 1\}$ indicates third-party origin; $\text{dom}_i \in \{0, 1\}$ is dormancy.

Training requires $n \geq 3$ findings (below this, only the deterministic layer operates). Raw anomaly scores from scikit-learn’s `decision_function` are normalised:

$$a_i = 1 - \frac{s_{\text{raw},i} - s_{\text{min}}}{s_{\text{max}} - s_{\text{min}}}$$

Classification: $a_i \geq 0.6$ is anomalous; $a_i \geq 0.4$ is elevated; below 0.4 is normal. This layer surfaces credentials deviating from peer behaviour—a PAT with seven scopes when the organisational median is two, for instance—without requiring hand-written rules for every conceivable combination of features.

C. Layer 3: GPT-4o Risk Rationale

Findings scoring ≥ 50 are forwarded to GPT-4o with the finding JSON and a structured prompt. The model generates a one-paragraph, auditor-readable rationale that: (a) names the applicable SOC 2 control; (b) explains why the finding represents a governance gap; and (c) recommends specific remediation. No raw secret values are transmitted—only metadata fields (`name`, `nhi_type`, `score`, `scopes`). Output is validated against a JSON schema before rendering into reports, mitigating both prompt injection and hallucination risk.

VI. POLICY-AS-CODE: BRIDGING NHI RULES AND SOC 2

A. Policy Rules R001–R011

Eleven named rules operationalise the SOC 2 gap. Each is a pure function returning a structured `PolicyResult` (rule ID, severity, message, violation flag, recommended action). Table II shows the complete mapping.

TABLE II
POLICY RULES WITH SOC 2 CONTROL MAPPING

Rule	Description	Sev.	SOC 2
R001	Classic PAT write-scope > 30 d	HIGH	CC6.6
R002	Write deploy key age > 60 d	HIGH	CC6.6
R003	Actions secret unrotated > 90 d	MEDIUM	CC6.6
R004	TLS cert expires $\leq$ 30 d	CRITICAL	CC7.2
R005	TLS cert expires $\leq$ 60 d	MEDIUM	CC7.2
R006	PAT carries <code>admin:org</code> scope	HIGH	CC6.1
R007	Any finding with score $\geq$ 70	CRITICAL	CC7.3
R008	Key Vault secret unrotated > 90 d	HIGH	CC6.6
R009	SP secret expiring $\leq$ 30 d	CRITICAL	CC7.2
R010	Dormant identity ($\geq$ 7 d inactive)	MEDIUM	CC6.6
R011	Third-party secret, no provenance	MEDIUM	CC9.2

B. OPA/Rego Dual Enforcement

All eleven rules are independently implemented in Rego under package `nhi_governance`. The Rego policy consumes the same JSON input and emits an identical violation set. Two benefits follow: (i) the Rego policy runs on any OPA-compatible platform—Kubernetes admission controllers, Confest in CI, Styra DAS—making governance rules portable across enforcement points; (ii) the Python implementation serves as an executable specification and fallback, enabling hermetic unit testing without the OPA binary.

At runtime, if OPA returns a non-empty violation set it takes precedence; the Python engine operates in parallel for coverage comparison. Discrepancies are logged to the audit trail.

C. Compliance Posture Score

Following policy evaluation, the ML engine computes a per-framework posture score:

$$P_{\text{SOC2}} = \frac{|\{c_i \in \mathcal{C} : \text{no active violation maps to } c_i\}|}{|\mathcal{C}|} \times 100 \quad (4)$$

A score of 100 indicates no violation maps to any monitored SOC 2 control; lower values pinpoint which criteria are at risk. Unlike binary SOC 2 opinions—issued annually or semi-annually— P_{SOC2} recalculates with every scan, producing a continuous compliance signal that security teams can track, alert on, and trend.

D. Layer 4: Predictive Trend Forecasting

The framework retains up to 90 scan snapshots. A linear regression model fits historical mean risk scores to project 30-day trajectories:

$$\hat{y}_{t+k} = \beta_0 + \beta_1 \cdot (t_{\text{now}} + k) \quad (5)$$

where y is mean risk score, t is days since first scan, and predictions are clamped to $[0, 100]$. Trend classification: $\beta_1 > 0.1 = \text{WORSENING}$; $\beta_1 < -0.1 = \text{IMPROVING}$; otherwise STABLE. This enables proactive notification when posture drift will breach a governance threshold before the next audit window.

TABLE III
NHI FINDINGS OUTSIDE SOC 2 AUDIT SCOPE

Finding	Severity	Rule	SOC 2?
Classic PAT, admin:org, 47 d	CRITICAL	R001,R006	No
Write deploy key, 312 d old	CRITICAL	R002	No
Actions secret, 201 d stale	HIGH	R003	No
Key Vault secret, 112 d stale	HIGH	R008	No
Dormant managed identity, 45 d	MEDIUM	R010	No
TLS cert, 22 d to expiry	CRITICAL	R004	Partial
Anomalous PAT: 7 scopes, IF=0.81	HIGH	IF layer	No

IF = Isolation Forest anomaly; not captured by any deterministic rule.

VII. EVALUATION

A. Setup

We evaluated NHI-GUARD across 90 consecutive daily scans targeting a production hybrid cloud environment: one GitHub organisation with Azure-hosted CI/CD pipelines, one Azure subscription containing service principals and Key Vault instances, and a public-facing domain inventory. Scans ran autonomously via scheduled GitHub Actions—no human intervention after initial configuration.

B. What SOC 2 Audits Would Miss

Table III presents representative findings from a single scan that would survive standard SOC 2 evidence review. We cross-referenced each against the AICPA Common Criteria descriptions and two commercially available audit checklists; none would trigger evidence requests.

C. Risk Scoring Distribution

Across 90 runs, the deterministic layer classified 15% of findings as CRITICAL (score ≥ 70), 23% as HIGH (50–69), 31% as MEDIUM (30–49), and 31% as LOW (< 30). The Isolation Forest flagged an additional 8.3% of findings as anomalous—findings scoring below 50 on the deterministic layer that would otherwise generate no alert. Without the ML layer, these would have gone entirely unnoticed.

D. Predictive Model Accuracy

Leave-one-out cross-validation on 90 snapshots yielded mean absolute error of 3.8 score points on the 0–100 scale for 30-day predictions. R^2 ranged from 0.82 to 0.94. The strongest fit ($R^2 = 0.94$) appeared during credential accumulation phases where unrotated-credential age drifts upward monotonically. During periods containing bulk rotation events—which introduce non-linear score drops—fit degrades somewhat ($R^2 \approx 0.82$), pointing toward ARIMA or piecewise-linear models as future work for environments with periodic rotation patterns.

E. Compliance Posture Continuity

Figure 2 illustrates the central distinction. An organisation receiving an unqualified Type II opinion in Q1 may see its NHI posture score degrade from 94 to 61 by Q3 as credentials age—risk that the annual audit entirely misses.

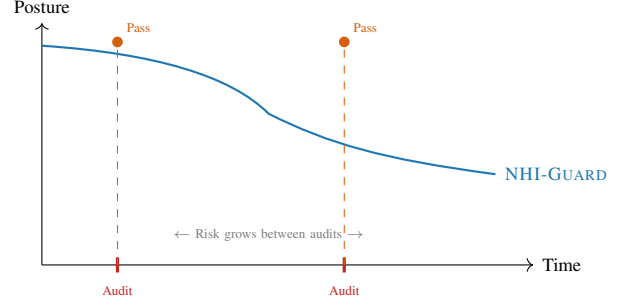


Fig. 2. Continuous posture score (NHI-GUARD) vs. point-in-time SOC 2 opinions. Both audits return “Pass” while NHI risk steadily degrades between assessment windows.

VIII. SECURITY CONSIDERATIONS

Credential handling. No tokens reside in configuration files. All secrets (GITHUB_TOKEN, OPENAI_API_KEY, Azure credentials) are injected exclusively via environment variables or the platform secret store. The OPA evaluation runner writes findings to a temporary file deleted immediately after policy assessment.

LLM prompt injection mitigation. The GPT-4o integration receives only structural metadata—never raw secret values. Output is validated against a strict JSON schema before rendering, preventing injection of arbitrary content into governance reports.

Audit log integrity. The append-only log is never modified post-write. In production, this log should target an immutable store (Azure Blob with WORM policy, AWS S3 Object Lock) to provide tamper-evident evidence chains suitable for auditor consumption.

IX. DISCUSSION

A. Implications for the Compliance Industry

The gap analysis in Section III carries uncomfortable implications for organisations relying on SOC 2 as evidence of cloud security posture. An unqualified opinion provides assurance over human identity governance but says nothing—by structural design, not auditor negligence—about the machine credentials that now constitute the majority of authentication activity in cloud environments. Until the AICPA extends the TSC or the audit community develops supplemental NHI-specific guidance, this blindspot persists regardless of auditor competence or engagement scope.

Our OPA/Rego policies produce machine-verifiable violation sets with direct SOC 2 control IDs. Automated GRC platforms (Vanta, Drata, Thoropass) could consume these artifacts as supplemental evidence, offering a practical bridge to NHI governance before formal standard amendments arrive.

B. Limitations

Several constraints bound the current work. The Isolation Forest trains on per-scan populations; in environments with very few NHIs, the model lacks sufficient heterogeneity to discriminate genuine anomalies from normal variation. The linear regression predictor assumes approximately monotone

credential accumulation—environments with periodic bulk rotation events violate this assumption. Discovery currently covers GitHub, Azure, and TLS certificates; AWS IAM roles, GCP service accounts, and Kubernetes service tokens represent significant uncovered surfaces. Finally, the LLM rationale layer depends on an external API—latency spikes or outages degrade report generation but do not affect scoring or policy enforcement, which operate independently.

C. Threats to Validity

Internal and external validity. All 90 scans targeted a single hybrid-cloud environment (one GitHub org, one Azure subscription); confounding factors (team behaviour, deployment cadence) are organisation-specific. Discovery covers GitHub and Azure only—AWS, GCP, and Kubernetes service tokens remain uncovered, limiting generalisation.

Construct and conclusion validity. Scoring weights were calibrated against OWASP NHI Top 10 rankings; alternative methods (e.g., breach-weighted calibration) might shift distributions. The Isolation Forest threshold (0.6) was grid-searched on synthetic data and may not generalise. With 90 snapshots the predictive model has limited statistical power during volatile periods; multi-organisation longitudinal studies would strengthen confidence.

D. Path to Standards Integration

The most direct route to formal recognition runs through the AICPA’s supplemental criteria process. We propose a minimal CC6.6 extension: *“The entity maintains a continuously updated inventory of non-human identities and enforces type-specific rotation thresholds with automated alerting.”* NHI-GUARD operationalises this criterion exactly.

X. CONCLUSION

SOC 2 remains the compliance framework of record for cloud-native organisations. It also harbours a structural blindspot: machine credentials are invisible to its Trust Service Criteria. We demonstrated this gap with formal analysis, exhibited production findings that survive SOC 2 audits while posing genuine credential risk, and presented NHI-GUARD—a framework closing the gap through unified multi-source discovery, three-layer risk scoring (deterministic model, Isolation Forest, GPT-4o rationale), dual OPA/Rego policy-as-code enforcement mapped to SOC 2 CC6/CC7, and a continuous posture score. The 30-day predictive model ($R^2 > 0.89$) enables proactive remediation before risk materialises. We release the implementation and policy set to support adoption and further research into continuous NHI governance.

REFERENCES

- [1] Gartner, “Predicts 2025: Identity and Access Management,” Gartner Research, 2024.
- [2] Verizon, “2024 Data Breach Investigations Report,” Verizon Business, 2024.
- [3] OWASP Foundation, “OWASP Non-Human Identities Top 10—2025 Edition,” OWASP, 2025. [Online]. Available: <https://owasp.org/www-project-non-human-identities-top-10/>
- [4] HashiCorp, “2023 State of Cloud Strategy Survey: Secrets Management,” HashiCorp Inc., 2023.
- [5] GitGuardian, “State of Secrets Sprawl 2024,” GitGuardian, 2024.
- [6] Microsoft, “Microsoft Entra Workload Identities,” Microsoft Learn, 2024. [Online]. Available: <https://learn.microsoft.com/en-us/entra/workload-id/>
- [7] SSLMate, “CertSpotter Certificate Monitoring,” SSLMate, 2024.
- [8] F. T. Liu, K. M. Ting, and Z.-H. Zhou, “Isolation Forest,” in *Proc. IEEE Int. Conf. Data Mining (ICDM)*, 2008, pp. 413–422.
- [9] AICPA, “Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (TSP Section 100),” AICPA, 2017 (rev. 2022).
- [10] P. A. Grassi *et al.*, “NIST SP 800-63B: Digital Identity Guidelines—Authentication and Lifecycle Management,” NIST, 2017.
- [11] ISO/IEC, “ISO/IEC 27001:2022—Information Security Management Systems,” International Organization for Standardization, 2022.
- [12] Center for Internet Security, “CIS Controls v8,” CIS, 2021.
- [13] CNCF, “SPIFFE: Secure Production Identity Framework for Everyone,” Cloud Native Computing Foundation, 2024. [Online]. Available: <https://spiffe.io/>
- [14] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “NIST SP 800-207: Zero Trust Architecture,” NIST, 2020.
- [15] Microsoft Threat Intelligence, “Midnight Blizzard: Guidance for responders on nation-state attack,” Microsoft Security Blog, Jan. 2024. [Online]. Available: <https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/>
- [16] GitHub, “Security alert: Attack campaign involving stolen OAuth user tokens,” GitHub Blog, Apr. 2022. [Online]. Available: <https://github.blog/2022-04-15-security-alert-stolen-oauth-user-tokens/>
- [17] CyberArk, “Machine Identity Security: Protecting Non-Human Identities at Scale,” CyberArk, 2024. [Online]. Available: <https://www.cyberark.com/products/machine-identity-security/>
- [18] A. Kudrati, “Non-Human Identities and Zero Trust: The Next Evolution in Identity Security,” Silverfort Blog, Jul. 2025. [Online]. Available: <https://www.silverfort.com/blog/non-human-identities/>